# SHIELD-AI™

## Security and Holistic Integrity for Enterprise-Level Deployment of AI

### Technical Deep Dive -- Framework Architecture, Controls & Implementation

Security Architecture Practice * v1.15 * September 28, 2026

# AGENDA

## 1. Architecture Overview

- Reference architecture -- control stack
- Threat landscape & attack taxonomy

## 2. Seven Pillars Deep Dive

- MS * IAM * DS * TP * MIR * GRM * EE
- Controls, decision trees, mappings

## 3. Regulatory & Standards

- AU frameworks, OWASP, NIST, EU AI Act, ISO 42001

## 4. Emerging Trends & Protocol Security

- Multi-agent, MCP, persistent memory, code-gen agents

## 5. Delivery & Operations

- Implementation methodology, continuous compliance
- Deployment topologies, reference implementation, deployable components

## 6. Reference & Appendices

# REFERENCE ARCHITECTURE -- SHIELD-AI™ CONTROL STACK

This is the anchor for every pillar. Each numbered area maps to a SHIELD-AI™ pillar.



# AGENTIC AI THREAT LANDSCAPE

Seven layers of attack surface -- controls must cover all of them

### 🧠 MODEL LAYER

Prompt injection, jailbreaking, model inversion, data extraction from responses, backdoor triggers

### 📊 DATA LAYER

Cross-session data aggregation, RAG pipeline poisoning, PII leakage in tool calls

### 🔧 TOOL LAYER

Tool output injection, malicious tool registration, API abuse, tool chain poisoning

### 🕹️ PIPELINE LAYER

CI/CD compromise, model update substitution, dependency chain poisoning

### 🔒 IDENTITY LAYER

### 🏛 GOVERNANCE LAYER

# WHY EXISTING FRAMEWORKS DON'T COVER AGENTIC AI

### ASD ISM (1,081 CONTROLS)

Zero AI-specific controls. March 2026 "Guidelines for secure AI system development" is introductory, not a control framework.

### ESSENTIAL EIGHT

Necessary but insufficient -- doesn't address prompt injection,

### OWASP LLM TOP 10

Threat taxonomy, not a framework with maturity levels, implementation guidance, or regulatory mapping.

### EU AI ACT

Risk classification + obligations. No technical controls defined.

### ISO/IEC 42001:2025

# SHIELD-AI FRAMEWORK -- 7 PILLARS X 60 CONTROLS

P1

## MODEL SECURITY

Weight protection, training integrity, supply chain, adversarial robustness, behaviour validation, inventory, context obfuscation, MCP controls

P2

## IDENTITY & ACCESS

Agent identity, scope-bound delegation, human oversight, credential isolation, JIT access, cross-session, delegation chains, credential scoping, multi-tenant isolation

P3

## DATA SECURITY

Classification, inference protection, memory sanitisation, minimisation, training governance, output validation

P4

## TOOL & PIPELINE

Tool registry, access control, API gateway, output validation, pipeline integrity, dependency scanning, chain analysis,

P5

## MONITORING & IR

Activity logging, anomaly detection, prompt audit, IR playbooks, reporting integration, forensic readiness

P6

## GOVERNANCE & RISK

Governance body, risk register, ethical use, third-party risk, regulatory mapping, board reporting

# SHIELD-AI VS "WE ALREADY USE NIST + OWASP + ISO 42001"

The most common technical objection, answered directly

| Dimension | NIST AI RMF + OWASP + ISO 42001 | SHIELD-AI |
|---|---|---|
| Framework count | 3 separate, each with different terminology | 1 unified framework |
| Maturity model | None -- no "where are we → where next" | 4 levels (L1-L4) with per-control progression |
| AU regulatory mapping | None -- must build custom mapping | Full ISM/E8/SOCI/CPS 234/PSPF/Privacy Act |
| Agentic-AI specificity | Partial -- NIST AI RMF covers general AI risk | Full -- 7 pillars designed for autonomous agents |
| | No -- process/procedure | |

# PILLAR 1: MODEL SECURITY (MS)

**MS-01** **Weight protection** -- encrypt at rest/transit, HSM-backed keys, remote attestation for edge — ISM

**MS-02** **Training data integrity** -- provenance tracking, sanitisation, poison detection pipeline — ISM, LLM04

**MS-03** **Supply chain** -- model provenance, ML SBOM, signed checkpoints — ISM, LLM10

**MS-04** **Adversarial robustness** — LLM01, NIST

## DECISION TREE: CHOOSING YOUR APPROACH

💡 **How to approach model security:**

**Q: Do you use third-party or self-hosted models?**

> Third-party → focus on MS-04 (prompt injection testing), MS-05 (output guardrails)
>
> Self-hosted → add MS-01 (weight encryption), MS-02 (training integrity)

**Q: How many models in production?**

> <5 → Manual inventory (MS-06

# PILLAR 2: IDENTITY & ACCESS (IAM)

IAM-01 **Agent identity** -- unique service identities per agent, not human credential sharing ISM E8

IAM-02 **Scope-bound delegation** -- tools scoped to agent function, no wildcards, no self-escalation LLM08

IAM-03 **Human oversight** -- approval gates for high-risk actions, break-glass with audit trail

IAM-04 **Credential isolation** -- agent

## DECISION TREE: CHOOSING YOUR APPROACH

💡 **Choosing your agent identity approach:**

**Q: How many agents?**

> <5 → OPA sidecar per agent (simplest path)
>
> 5-50 → Central OPA gateway (single policy enforcement point)
>
> 50+ → OPA + SPIFFE/SPIRE for workload identity (scales)

**Q: Multi-agent architecture?**

# PILLAR 3: DATA SECURITY (DS)

**DS-01** **Data classification** -- automated tagging per PSPF/ISM at ingestion — ISM

**DS-02** **Inference protection** -- TLS 1.3, end-to-end encryption of prompts/responses

**DS-03** **Memory sanitisation** -- no sensitive data across sessions; retention policies; automated purging — LLM06

**DS-04** **Data minimisation** -- field-level filtering in retrieval layer, no bulk data

## DECISION TREE: CHOOSING YOUR APPROACH

💡 **How to approach data security:**

**Q: Does your agent use persistent memory?**

> Yes → DS-03 is highest priority: retention policies, automated purging, per-agent scoping
>
> No → Defer DS-03, focus on DS-01 (classification) and DS-04 (minimisation)

**Q: RAG pipeline?**

> Yes → Implement ABAC at retrieval

# PILLAR 4: TOOL & PIPELINE SECURITY (TP)

TP-01 **Tool registry** -- all tools registered, versioned, security-approved

TP-02 **Tool access control** -- least-privilege per agent, tool authenticates agent

TP-03 **API gateway** -- rate limiting, schema validation, audit logging on agent-facing APIs

TP-04 **Tool output validation** -- structural validation, sanitisation before agent context LLM02

## DECISION TREE: CHOOSING YOUR APPROACH

💡 **Choosing your deployment topology:**

> <10 agents → Embedded library (simplest, framework-native)
>
> 10-100 agents → Sidecar proxy (balanced isolation vs overhead)
>
> 100+ / multi-agent → Central gateway for external, sidecars for cross-agent

# PILLAR 5: MONITORING & IR (MIR)

**MIR-01** **Activity logging** -- every tool call, data access, decision; agent ID + session + correlation ID

**MIR-02** **Anomaly detection** -- per-agent and per-class baselines; deviation alerts

**MIR-03** **Prompt audit log** -- sanitised prompt/response pairs, recoverable for IR

**MIR-04** **IR playbooks** -- prompt injection containment, model rollback, tool revocation

**MIR-05** **Mandatory reporting** SOCI CPS 234

## DECISION TREE: CHOOSING YOUR APPROACH

💡 **How to build agent telemetry:**

**Q: Existing SIEM?**

> Splunk/SOAR/ELK → Deploy agent telemetry as structured JSON events via OTLP
>
> None → Start with cloud logging (CloudWatch, Azure Monitor, GCP Cloud Logging)

**Q: Multi-agent architecture?**

> Yes → Distributed tracing header across all agents; single audit trail

# PILLAR 6: GOVERNANCE & RISK (GRM)

GRM-01 **AI governance body** -- CISO, CRO, GC, data owner, AI lead with charter CPS 234

GRM-02 **AI risk register** -- distinct taxonomy for model/tool/data/identity/pipeline risks

GRM-03 **Ethical use policy** -- acceptable use, human-in-the-loop by risk tier, transparency

GRM-04 **Third-party AI risk** -- vendor assessment, contractual controls, right-to-audit LLM10

## DECISION TREE: CHOOSING YOUR APPROACH

💡 **How to build AI governance:**

**Q: Existing risk/compliance function?**

> Mature (APRA-regulated) → GRM-01 (chartered committee), GRM-02 (risk register), GRM-05 (automated mapping)
>
> Developing → Start with GRM-06 (dashboard -- shows posture without formal governance)

**Q: Using external model providers?**

# PILLAR 7: EXECUTION ENVIRONMENT (EE)

E8

EE-01 **Boundary enforcement** -- container/VM isolation, no shared mounts/namespaces, immutable infra, fail-closed

EE-02 **Infrastructure API control** -- no implicit access to EC2/IAM/Lambda/S3 control planes

EE-03 **Resource limiting** -- CPU/memory/network/storage/API rate bounds; exceed = alert or terminate

EE-04 **Evaluation sandbox integrity** -- eval isolated from prod, no network path, no prod

## DECISION TREE: CHOOSING YOUR APPROACH

💡 **How to build the execution boundary:**

**Q: Container or VM?**

> <10 agents → Per-agent containers with hardened runtime profiles
>
> Untrusted/unverified code → MicroVM or VM-level isolation (no virtiofs/9p passthrough)

**Q: Does the agent execute LLM-generated code?**

> Yes → EE-06 is mandatory; runtime

# MATURITY MODEL -- LEVEL-UP GUIDANCE

| Area | L1 Initial | L2 Managed | L3 Defined | L4 Optimised | How to Le Up (exam IAM) |
|---|---|---|---|---|---|
| **MS** | Basic inventory | Supply chain verification | Adversarial testing programme | Automated red-teaming | L1→L2: Sig ML SBOM L2→L3: Deploy CI/ prompt injection tests. L3→ Continuou red-teami |
| | | Per-agent | | | L1→L2: Ea agent gets identity. L2 >L3: OPA |

# MCP PROTOCOL & AGENT-TOOL INTERFACE SECURITY

## ✅ SECURITY BENEFITS OF MCP

Standardised interfaces enable standardised controls. MCP defines tool discovery schemas, typed tool interfaces (JSON Schema), and structured error responses -- making generic tool security proxies possible.

## SHIELD-AI MCP CONTROLS

**TP-03 extended:** MCP gateway enforces auth, schema validation, rate limiting at protocol layer. **TP-04 extended:** MCP response validation against known-good schemas. **MS-04 extended:** MCP protocol-layer adversarial testing.

## ⚠️ MCP ATTACK SURFACE

## MCP GATEWAY ARCHITECTURE

# EMERGING: MULTI-AGENT SYSTEMS & AGENT SWARMS

## ARCHITECTURE CHANGES

- **Delegate** tasks to other agents -- delegation chains
- **Share context** -- one agent's output is another's input
- **Coordinate** -- interdependent multi-agent workflows

## BLAST RADIUS MULTIPLIER

A single compromised agent poisons every downstream agent's context. Prompt injection

## IAM-02: BOUNDED DELEGATION CHAIN

Agent-to-agent must not expand original scope. Each hop respects bounds -- no escalation across delegation chains.

## MIR-01: DISTRIBUTED TRACING

Single user request → chain of agent calls reconstructable as one

# EMERGING: PERSISTENT AGENT MEMORY

## DATA AGGREGATION RISK

- Agent remembers User A's financial details
- User B queries in Session 2 -- cross-reference possible
- Memory embedding spaces encode sensitive correlations

## ATTACK VECTORS

**Memory-read:** compromised session reads another session's data. **Memory poisoning:** crafted inputs trigger unintended

## DS-03: MEMORY SANITISATION (HIGHEST PRIORITY)

Retention policies with automated purging. Cross-session aggregation detection. Per-agent memory scoping. Encryption at rest.

## DS-04: MEMORY MINIMISATION

Only essential data remembered. Memory scoped per-agent and per-task -- not shared across

# EMERGING: AUTONOMOUS CODE GENERATION

The highest-risk agent capability -- treat accordingly

| Level | Capability | Human Approval |
|---|---|---|
| 1 | Generate SQL queries | Always |
| 2 | Generate shell commands | Always |
| 3 | Generate config files | Always |
| 4 | Self-heal -- patch own code | Always + sandbox |
| 5 | Write and deploy microservices | Multi-party approval |

**TP-01: CODE EXECUTION AS TOOL CLASS**

Distinct class with highest security. Must be explicitly enabled per agent -- never default-on.

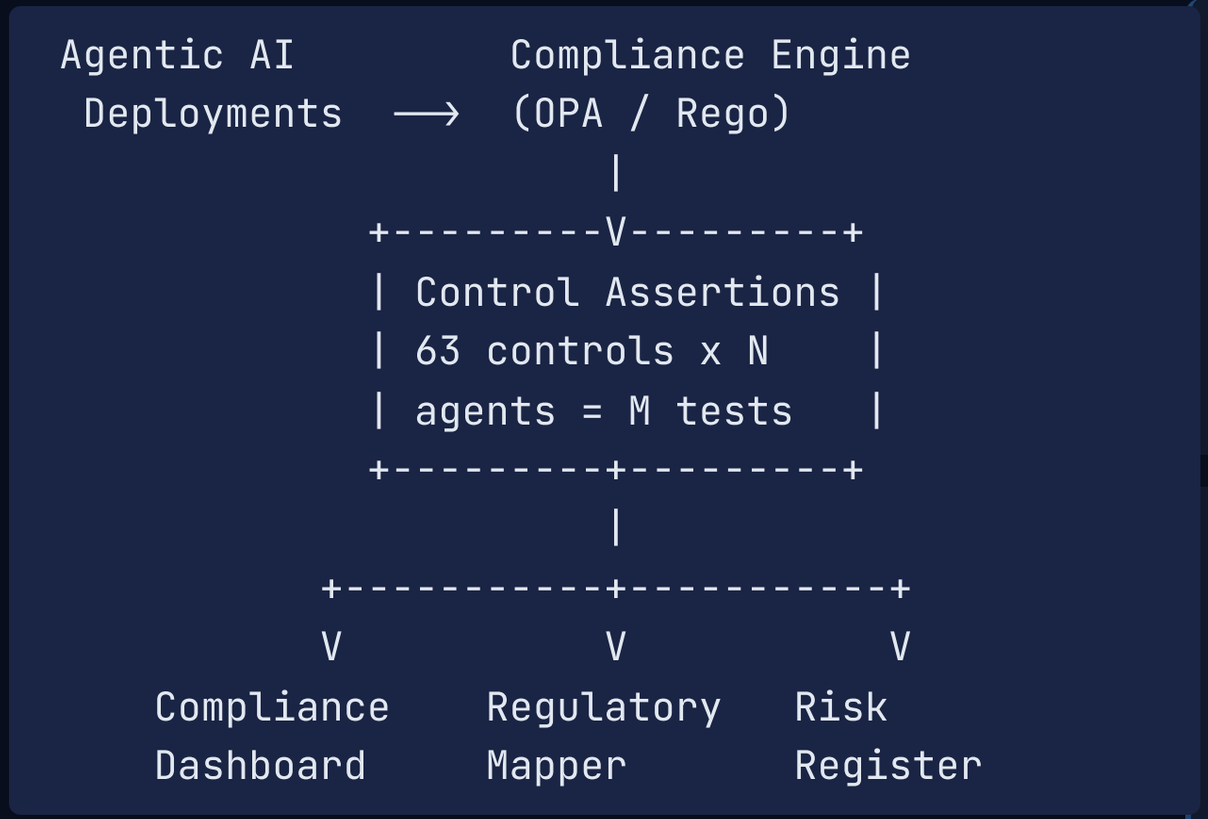
**TP-04: CODE OUTPUT VALIDATION**

Sandbox-executed and output-

# AU REGULATORY MAPPING

| SHIELD-AI | ISM | E8 | SOCI Act | CPS 234 | Privacy Act |
|---|---|---|---|---|---|
| MS-01 | Cryptography | - | CIRMP s.4(a) | s.3(b) | APP 11 |
| IAM-01 | Sys Mgmt | Restrict Priv | - | s.3(b) | - |
| IAM-02 | Sys Mgmt | - | CIRMP s.4(b) | s.3(a) | - |
| DS-01 | Data Transfers | - | - | s.3(a) | APP 5,6 |
| DS-03 | Media | - | - | - | APP 11 |
| TP-01 | Gateways | Patch Apps | CIRMP s.4(c) | s.3(b) | - |
| MIR-01 | Monitoring | - | s.30B(5)(a) | s.3(c) | NDB |
| MIR-05 | Incidents | - | s.30B(5)(c) | s.3(c) | NDB |
| GRM-01 | Roles | - | CIRMP s.4(d) | s.2 | APP 1 |

# CONTINUOUS COMPLIANCE AUTOMATION




## 1. CONTROL AS CODE

Every SHIELD-AI control = machine-readable assertion (Rego policy, CI/CD test, etc.)

## 2. CONTINUOUS TESTING

Critical controls: every 15 min. Config controls: daily. Dashboard with trend data.

## 3. REGULATORY CHANGE DETECTION

# DEPLOYMENT TOPOLOGIES -- DECISION TREE

### <10 AGENTS

**Embedded library** -- security controls via agent framework SDK/plugin. Low latency, simple config. *Best for: pilots, single-agent PoCs.*

### 10-100 AGENTS

**Sidecar proxy** -- per-agent sidecar (OPA + tool gateway + telemetry). *Best for: K8s deployments, existing service mesh.*

### 100+ / MULTI-AGENT

**Central gateway + sidecar audit** -- gateway for external tools, sidecars for cross-agent monitoring. *Best for: enterprise, regulated, multi-agent systems.*

### PROS

No infra dependency, consistent with framework API

### PROS

Isolation per agent, no SPOF, consistent with sidecar mesh

### PROS

Single policy point, central

# BUILD-VS-BUY ANALYSIS

| Factor | Build In-House | Adopt SHIELD-AI |
|---|---|---|
| Time to capability | 12-18 months | 4-16 weeks |
| Hiring | 3-5 specialists (6-9mo to hire) | None -- implementation team delivers |
| Framework depth | Inexperienced, likely gaps | 63 controls, 12+ framework mappings |
| Regulatory confidence | Low -- untested | High -- auditable mappings |
| Incident learnings | Reactive -- each incident a new lesson | Built-in -- 47 documented incidents drive the control set |

## WHY ADOPT

Every control is a documented, testable assertion with implementation guidance -- not a policy binder. Deployable components are specified in the implementation architecture document.

## WHY BUILD FAILS

The threat landscape moves monthly (CrewAI, Codex CLI, CVE-

# MATURITY LEVELS -- TECHNICAL SUMMARY

| Capability | L1 Initial | L2 Managed | L3 Defined | L4 Optimised |
|---|---|---|---|---|
| Assessment scope | Single pilot / PoC | Priority AI systems | Full agentic AI estate | Multi-entity / cross-border |
| Control implementation | Basic model controls | Documented controls, per-agent accounts | Automated L3 deployment | Custom control development |
| Technical tooling | Manual inventory | Model registry, basic gateway | OPA policies, tool gateway, SIEM dashboards | + Threat intel, red-teaming platform |

# KEY TECHNICAL TERMS

| Term | Definition | Control |
|---|---|---|
| MCP | Standardised protocol for agent-tool discovery and invocation | TP-03, TP-04 |
| A2A Protocol | Standard for direct inter-agent communication and delegation | IAM-02, MIR-01 |
| Policy-as-Code | Security policies as machine-readable, testable assertions (OPA/Rego) | GRM-05, IAM-02 |
| Tool Output Injection | Compromised tool returns crafted data to manipulate agent behaviour | TP-04, DS-06 |
| Agent SBOM | Software bill of materials: model, tools, libraries, pipeline, runtime | MS-03, TP-06 |
| RAG Security Layer | ABAC at retrieval + field-level redaction before model context | DS-01, DS-04 |
| Agent Telemetry | Structured event stream: tool calls, data access, decisions, errors | MIR-01, MIR-02 |
| Bounded Delegation | Each agent-to-agent hop respects original scope -- no escalation | IAM-02 |
| Continuous Compliance | Control verification runs continuously, not point-in-time | GRM-05, GRM-06 |
| MCP Gateway | Security proxy for MCP protocol: auth, schema, audit, rate-limiting | TP-03 |

# TRY IT TODAY -- IMPLEMENTATION ARCHITECTURE

### 💻 IMPLEMENTATION ARCHITECTURE

framework/shield-ai-implementation-architecture.md -- deployable components, reference architecture, full SVG diagram set, component-to-control mapping.

### 📋 POLICY-AS-CODE

policies/ -- 36 Rego stubs covering MS, IAM, DS, TP, MIR, GRM. Wire them into the OPA decision points from the architecture document.

### 🚀 ASSESSMENT TOOLKIT

The assessment guide scores all 63 controls per pillar. Control schema (JSON) is machine-readable for tooling.

# QUESTIONS & DISCUSSION

SHIELD-AI v1.15 -- September 28, 2026

Security Architecture Practice

Full framework document • Implementation architecture (deployable components + diagrams) • Gap analysis • Assessment guide